Artifact Signing and Attestation Policy

Meridian Capital - Technology Risk Management

Document Identification and Control

Document ID: MC-TRM-SP-ASA-001

Title: Artifact Signing and Attestation Policy

Classification: Internal Use Only

Version: 1.0.0

Effective Date: 2026-04-15T00:00:00Z

Next Scheduled Review: 2027-04-15T00:00:00Z

Policy Owner: Security Architecture & Engineering (SAE)

Control Owner: Cryptographic Services & PKI (CSPKI)

Author: DevSecOps Program Office (DSO)

Primary Repository: TRM Confluence Space (REF: CNF-TRM-7321)

Change Control: CAB CRQ-2026-04421 (Approved 2026-04-08T14:35:00Z)

Approval Record: CISO Approval Ticket SEC-APP-2026-1187 (2026-04-10T09:12:44Z), CTO Co-Sign CTO-REF-2026-031 (2026-04-11T17:02:06Z)

Audit Traceability: Audit Plan Reference IAA-PLN-2026-19; Control Mapping RCM-ASA-2026-05

1. Overview and Purpose

This policy establishes Meridian Capital's enterprise-wide requirements for cryptographic signing and attestation of software artifacts to ensure integrity, authenticity, provenance, and accountability across the software supply chain. It defines the minimum controls and governance necessary for build outputs, infrastructure-as-code packages, container images, machine learning model bundles, and other deployable units to be trusted within Meridian Capital's environments. The policy seeks to mitigate risks of artifact tampering, unauthorized distribution, ambiguous asset lineage, and inadequate traceability that may result in operational disruption, regulatory findings, or client impact.

The scope of this document encompasses the normative requirements for artifact signing and attestation, the delineation of responsibilities across platform and product teams, the compliance metrics used to assess control effectiveness, and the mechanisms for independent assurance. The policy aligns with Meridian Capital's Technology Risk Management Framework (TRMF) and complements the Secure Software Development Standard (MC-TRM-SSD-002), the Vulnerability Management Standard (MC-TRM-VMS-004), and the CI/CD Governance Standard (MC-TRM-CICD-007). It also maps to external expectations expressed in NIST SSDF practices, the Supply-chain Levels for Software Artifacts (SLSA) objectives, and sectoral regulatory obligations for software change control and operational resilience.

2. Policy Intent and Principles

The intent of the policy is to require that all artifacts promoted beyond development environments possess verifiable cryptographic signatures and attestation records sufficient to establish an unbroken chain of custody from source to release. These controls are principle-based and emphasize determinism, transparency, and fail-safe gating within the software delivery process. Policy application is technology-agnostic with respect to build systems and packaging formats, provided the requisite properties of signer identity, tamper-evidence, and auditable provenance are preserved.

To prevent ambiguity in trust decisions, signer identities must be rooted in centrally governed trust anchors, and attestations must be generated by controlled automation under the oversight of corporate services. Attestation content

must be materially complete to support regulatory inquiry and incident reconstruction without exposing sensitive implementation details unnecessarily. The principles of least privilege, segregation of duties, and non-repudiation guide the management of signing authorities and the evaluation of attestations at promotion and deployment gates.

3. Authority and Enforcement

This policy is issued under the authority of the Chief Information Security Officer and the Chief Technology Officer. Compliance is mandatory across all lines of business, technology domains, and subsidiaries operating under the Meridian Capital brand. Enforcement occurs through automated policy evaluations at CI/CD promotion points, registry admission controls, and runtime admission policies governed by centrally managed trust policies. Non-compliant artifacts are not eligible for promotion, distribution, or execution in controlled environments. The Technology Risk Management function monitors adherence through defined key performance indicators and reports status quarterly to the Technology Risk Committee.

4. Background and Drivers

Meridian Capital's 2025-2026 Software Supply Chain Assurance Review (TRM-ASR-2026-04) identified the need for consolidated artifact assurance controls amid increasing heterogeneity in build pipelines and packaging formats. Findings noted duplication of local signing practices, inconsistent attestation schemas, and insufficient lineage capture for infrastructure templates. While no client-facing incidents were attributed to artifact integrity during the review period, internal audit observation IAA-OBS-2025-33 recommended centralized governance, uniform metrics, and a formal policy to define minimum viable attestation content. External drivers include industry guidance on software supply chain transparency and regulator expectations for audit-ready provenance of production changes (see Compliance Note REG-CN-2026-12).

5. Document Governance and Maintenance

This policy is maintained by the DevSecOps Program Office with technical stewardship by Cryptographic Services & PKI and Security Architecture & Engineering. A comprehensive review is conducted annually or upon material change to trust anchors, regulatory obligations, or enterprise build services. Proposed revisions are initiated via TRM Ticket TRM-POL-CHANGE with linkage to CAB request records and security architecture review notes. The authoritative version is maintained in the TRM Confluence Space; derivative copies are informational only. Revision history and prior approvals are preserved for a minimum of seven years consistent with records retention schedules (Records Policy REF: RIM-2024-09).

6. Related Documents and References

- Secure Software Development Standard (MC-TRM-SSD-002; REF CNF-TRM-SSD-002)
- CI/CD Governance Standard (MC-TRM-CICD-007; REF CNF-TRM-CICD-007)
- Key Management and Cryptography Standard (MC-TRM-KMS-003; REF CNF-TRM-KMS-003)
- Software Composition and SBOM Standard (MC-TRM-SBOM-006; REF CNF-TRM-SBOM-006)
- Records Management Policy (RIM-2024-09; REF CNF-RIM-2024-09)
- Audit Control Matrix for Artifact Assurance (RCM-ASA-2026-05)

Crosswalks to external frameworks and regulatory references are documented in the Control Mapping Appendix (RCM-ASA-2026-05-APP).

7. Effective Date and Transition Guidance

The policy is effective as of 2026-04-15T00:00:00Z following CAB approval CRQ-2026-04421. Program-level adoption milestones are tracked under Initiative Portfolio ID DSO-PORT-2026-08 with quarterly checkpoints. Internal readiness assessment DSO-READ-2026-12 completed on 2026-03-28T16:48:19Z indicates that enterprise services required to

satisfy this policy are operational and available to product teams. This policy supersedes prior guidance contained in Advisory TRM-ADV-2025-21 and formalizes controls that had been operating under interim directives.

8. Scope and Applicability

This policy applies to all software and infrastructure artifacts that are created, modified, or distributed by Meridian Capital and are intended for deployment, promotion, or execution in any non-development environment, including test, staging, pre-production, production, and disaster recovery. Applicability spans:

- Build outputs such as compiled binaries, libraries, container images, and platform plug-ins.
- Infrastructure-as-code and platform configuration packages, including but not limited to templates, charts, and modules that effect changes to compute, network, storage, and security configurations.
- Data processing components such as scheduled jobs, ETL/ELT packages, and streaming topology bundles where deployment artifacts are versioned and promoted.
- Machine learning model artifacts and associated inference/runtime packages managed through sanctioned model registries.
- Third-party artifacts imported via approved registries, repositories, or vendor platforms where Meridian Capital exerts control over promotion into enterprise environments.

Artifacts generated exclusively for ephemeral developer experiments confined to isolated sandboxes without any pathway to enterprise environments fall within the conceptual remit of the policy but are considered non-promotable until compliant signatures and attestations are present. All shared environments, including enterprise-wide sandboxes and integration test spaces, are classified as controlled environments for the purposes of this policy.

9. Definitions and Terminology

For the purposes of this policy, the following definitions apply:

- Artifact: A discrete, versioned unit of deployable software or configuration produced by a build or packaging process and distributed via a repository or registry under enterprise governance.
- Signing: The application of a cryptographic signature to an artifact to establish authenticity and provide tamper-evidence, verifiable against a recognized trust anchor.
- Attestation: A structured, verifiable statement bound to an artifact that conveys provenance and contextual evidence regarding how, when, and by whom the artifact was produced, tested, and approved for promotion.
- Provenance: The set of data describing the origin of an artifact, including source repository identifiers, commit references, controlled build environment identifiers, and build workflow metadata.
- Trust Anchor: A centrally governed and auditable root of trust used to validate signer identities and signatures across the enterprise.
- Non-repudiation: Assurance that the entity that performed a signing action cannot plausibly deny responsibility due to the use of governed identities and controls.
- Freshness: The condition in which an attestation remains within policy-defined temporal bounds relative to the artifact's promotion or deployment event.

These definitions support consistent interpretation across teams and are harmonized with Meridian Capital's cryptography and software development standards.

10. Governance and Roles

The following governance structure is established to ensure effective operation, oversight, and assurance of artifact signing and attestation:

- Security Architecture & Engineering (SAE) serves as policy owner, defines control objectives, and approves trust anchor design. SAE maintains the reference architecture for artifact assurance services and validates architectural conformance through design reviews (ARC Review Queue: SEC-ARC-2026).

- Cryptographic Services & PKI (CSPKI) acts as control owner and service provider for enterprise signing and trust validation capabilities. CSPKI governs signer identity lifecycle, trust anchor configuration, and service health reporting (Service ID: SVR-CSPKI-09).
- Platform Engineering (PE) delivers and operates CI/CD platform integrations, registry admission controls, and deployment policy engines that enforce compliance. PE tracks adherence through platform telemetry (KPI Registry: PE-KPI-ASA).
- DevSecOps Program Office (DSO) coordinates cross-team adoption, manages communications, and reports progress to the Technology Risk Committee. DSO maintains the enterprise rollout plan and readiness assessments (Portfolio DSO-PORT-2026-08).
- Release & Reliability (R&R) ensures release pipelines implement mandatory promotion gates and monitors artifact promotion events for policy alignment. R&R maintains operational runbooks and on-call dynamics for assurance services (Ops Calendar: RNR-OPS-ASA).
- Technology Risk Management (TRM) provides second-line oversight, maintains control testing plans, and consolidates quarterly risk reporting. TRM schedules and executes design effectiveness and operating effectiveness tests (Test Plan TRM-TEST-ASA-2026).
- Internal Audit (IA) performs independent assurance per the annual audit plan and reviews adherence to retention and traceability requirements (Audit Casebook: IAA-PLN-2026-19).
- Lines of Business Engineering Teams are accountable for producing policy-compliant artifacts and ensuring that their delivery pipelines engage approved assurance services. Engineering teams must maintain accurate inventory mappings between services and artifacts in the Configuration Management Database (CMDB Ref: CMDB-CI-ASA).

11. Control Objectives

The policy defines the following control objectives as measurable outcomes:

- Integrity: All promotable artifacts bear a valid enterprise-recognized signature at the time of promotion, registry admission, and deployment decision.
- Authenticity and Accountability: Signer identities are uniquely attributable to controlled automation or authorized roles with clear ownership and audit trails.
- Provenance and Traceability: Attestations provide sufficient detail to reconstruct source-to-release lineage, including linkage to code review events, build workflows, and test evidence identifiers.
- Freshness and Relevance: Attestations remain within defined temporal thresholds relative to the promotion or deployment event to prevent stale or ambiguous assurance signals.
- Revocation and Response Readiness: Trust anchors and signer identities are managed to support prompt revocation and environment-wide policy updates with auditable change control.

12. Compliance Measurement and Reporting

Compliance is monitored through enterprise metrics aggregated by Platform Engineering and validated by TRM. Primary indicators include signing coverage rate for promotable artifacts, successful attestation verification rate at promotion gates, attestation freshness conformance, and time-to-remediate for non-compliant promotion attempts. Reporting is standardized via the Artifact Assurance Dashboard (DASH-ASA-2026), updated daily at 03:15Z with data sourced from CI/CD telemetry, registry admission logs, and policy decision records. Quarterly summaries are filed under TRM Report TRM-QBR-ASA-2026 with attachments enumerating control test results and remediation tracking (e.g., REM-ASA-2026-Q2-014). The Technology Risk Committee minutes (TRC-MIN-2026-06-27) record the acceptance of these metrics and any mandated improvement actions.

The above governance, scope, and objectives form the foundation for the mandatory requirements and operational

expectations that follow in subsequent sections of this policy. All teams are expected to align delivery practices and service configurations with these tenets to ensure sustained and auditable artifact trust across Meridian Capital's technology estate.

2. Scope and Applicability

This policy applies to all software and data artifacts produced, modified, or distributed within Meridian Capital computing environments, irrespective of hosting model or deployment tier. Artifacts in scope include, but are not limited to, compiled application binaries, container images, virtual machine images, shared libraries, mobile application packages, infrastructure-as-code modules, configuration bundles, database migration scripts, ETL/ELT jobs, machine learning feature stores and models, serverless function packages, and internal command-line tools. In-scope artifacts also encompass metadata outputs such as software bills of materials (SBOMs), provenance attestations, build manifests, and release notes generated by enterprise build and release pipelines. Where business units procure third-party software or managed services that deliver deployable artifacts into Meridian environments, this policy governs the intake, verification, and ongoing validation of supplier attestations and signatures to the extent technically feasible and contractually supported.

The policy is enterprise-wide and extends across Global Markets Technology, Wealth Management Platforms, Corporate Functions IT, Treasury Operations Systems, Quant Research Compute, and Shared Services. Both persistent and ephemeral environments are covered, including development, system integration testing (SIT), user acceptance testing (UAT), pre-production, production, high-performance compute (HPC) clusters, and disaster recovery sites. Artifacts intended for internal experimental use are in scope once transmitted, stored, or executed within Meridian networks or integrated platforms. This delineation is recorded in GRC ticket GRC-AR-22691 (opened 2026-01-19T11:42:07Z) and ratified in the Security Architecture Review Board (SARB) minutes SARB-2026-02-06-Item4.

Enterprise platform components subject to this policy include the Meridian Build Fabric (MBF), Meridian Artifact Repository (MAR), Enterprise Signing Service (ESS), and the Continuous Compliance Telemetry Lake (CCTL). These platforms operate under the custodianship of Cloud Platform Engineering (CPE) and Secure Build Services (SBS), with operational guardrails documented in Change Advisory Board entry eCAB-2026-03-14-078. Integration points with Secrets Governance and Key Management Services (KMS) are maintained by the Enterprise PKI and Cryptographic Services team, with responsibility boundaries tracked in Ops Catalog entry OPS-CAT-SEC-0172, last updated 2026-04-02T08:10:55Z.

This policy governs both origin-signed artifacts (produced within Meridian pipelines) and intake-signed artifacts (originating from third parties and validated upon ingestion). Intake workflows are coordinated with Vendor Risk Management (VRM) to establish supplier assertion formats and verification evidence (reference VRM-INTK-5941, 2026-02-23T16:28:11Z). When supplier ecosystems evolve (e.g., upstream signing format changes), the cross-functional Impact Assessment Forum (IAF) convenes to evaluate operational implications and evidence continuity; see IAF memo IAF-2026-Q1-M04.

The policy aligns to Meridian control families SEC-ASAP-01 through SEC-ASAP-10 under the Information Security Management System (ISMS). The alignment map is maintained by Governance, Risk, and Compliance (GRC) and references industry frameworks including ISO/IEC 27001 Annex A controls relevant to secure development and change, NIST SP 800-218 (SSDF) sections on provenance and integrity, and FFIEC guidance regarding change governance for financial institutions. The traceability matrix SEC-TRC-0029 (rev 3.1, approved 2026-03-05T13:03:29Z) associates this policy's provisions with SOX ITGCs related to program changes and access.

Systems that distribute or deploy artifacts--such as release orchestration tools, cluster schedulers, and platform-as-a-service components--are consumers of signatures and attestations and are therefore within the chain of accountability. Distribution platforms operated by Site Reliability Engineering (SRE) for Cloud Runtime Services must verify signatures and enforce attestation-based policy decisions as part of their standard gatekeeping functions, with outcomes recorded to CCTL for audit analytics. Monitoring and alerting functions run by Security Operations (SecOps)

consume failure signals to initiate incident triage (see incident template SECOPS-IM-Template-17).

Inherited obligations apply to joint ventures, subsidiaries, and strategic partners where Meridian asserts operational control over the build and deployment systems. Transitional arrangements for acquired entities are tracked via Integration Program Office records, with baseline conformance milestones captured in IPO-ART-2218 through IPO-ART-2224. As of baseline assessment CR-MBF-18644 (2026-03-07T09:12:18Z), all core lines of business have onboarded to ESS for origin signing, with two special-purpose research clusters scheduled for attestation telemetry integration by 2026-08-31 per Program Plan PMO-SEC-PL-2026-07.

Where data classification influences artifact handling, the Data Governance Council (DGC) stipulates that signing and attestation status be included among movement controls for artifacts associated with Confidential and Restricted data flows. This interaction is documented under DGC resolution DGC-2026-01-22-R2. The Records Retention function classifies signature and attestation artifacts as "Security Control Records" under retention class RR-17, with handling requirements cross-referenced to the Corporate Records Retention Policy FIN-REC-07.

For clarity, this scope statement does not narrow obligations by technology stack, hosting choice, or vendor selection; rather, it defines a uniform control baseline that is applied consistently enterprise-wide. Any future updates to the scope require SARB review and eCAB approval with a corresponding GRC impact assessment, and must be recorded with complete lineage in the Policy Library System of Record (PL-SOR) under document key POL-SEC-ASAP-2026-v1.x.

3. Roles and Responsibilities

Policy execution is distributed across defined roles to ensure clear accountability and uninterrupted operations. The Artifact Owner is accountable for the completeness and accuracy of attestations that describe build provenance, dependencies, and control posture for each release. Artifact Owners are designated in the Enterprise CMDB (CI attribute sec.artifactOwner) and must be traceable to a named individual within the relevant delivery organization. Ownership mapping evidence is maintained in GRC case GRC-OWN-3347 (consolidated quarterly; latest consolidation 2026-04-10T10:47:02Z).

Secure Build Services (SBS) is the control owner for origin signing within enterprise-managed pipelines. SBS operates ESS and ensures its availability, performance, and adherence to enterprise change governance. SBS coordinates with Cloud Platform Engineering (CPE) to maintain the reliability of MBF and MAR. Service reliability targets and supporting metrics (availability, verification latency, signature throughput) are tracked via SLO register SLO-SBS-ESS-2026 and reported to the Technology Risk Committee monthly. Service incidents and changes are governed under standard tickets (e.g., INC-ESS-2026-03-219, CHG-ESS-2026-04-082) with post-implementation reviews stored in the Service Management system.

The Enterprise PKI and Cryptographic Services team is the custodial owner of trust anchors and trust policy configuration used by verification systems. This includes lifecycle management, governance attestation, and audit evidence for key material and associated policy artifacts. The team maintains alignment with enterprise cryptographic standards and coordinates recertification cycles documented in CRY-KEY-LCM-Plan-2026 (approved 2026-02-28T15:55:44Z). Trust policy changes require Security Architecture Review Board endorsement and eCAB approval, with risk notes filed under SARB-RN-2026-05-03.

DevSecOps Leads within each product area oversee integration between development workflows and signing/attestation controls. Their remit includes ensuring SBOM generation, attestation completeness, and successful signature verification within pre-production gates. Integration milestones, gaps, and remediation tasks are tracked in JIRA program boards (e.g., ARTS-Program-Board-42), with consolidated progress updates posted to the monthly Engineering Risk Forum (ERF) notes ERF-2026-04-Minutes.

Release Management Offices (RMO) act as control validators at cutover and are responsible for ensuring that release packages present a verifiable signature and an attestation bundle mapped to the approved change. RMO records the verification outcomes in release tickets, with mandatory metadata fields capturing signer identity, verification timestamp, and attestation coverage. Sample evidence sets are filed in REL-EVD-2026-Q1-SetB and are retrievable through the Evidence Repository upon request by Internal Audit.

Security Operations (SecOps) consumes verification failure signals and operates the triage playbook for signature or attestation anomalies. SecOps coordinates with SBS and Artifact Owners to isolate affected distribution endpoints, assess impact, and restore control compliance. Incident categorizations utilize the enterprise severity model (SEV-1 through SEV-4) with service record cross-references to impacted systems. Evidence linkage for a recent SEV-3 verification failure was captured under SECOPS-IM-2026-03-118 (opened 2026-03-19T03:14:21Z; closed 2026-03-20T12:02:08Z) with a root cause attributed to stale attestation metadata in a downstream consumer.

Governance, Risk, and Compliance (GRC) functions as the policy steward and evidence custodian. GRC manages the policy lifecycle, oversees control testing, and maintains the control-to-regulatory mapping. Quarterly control effectiveness assessments and sample-based testing outcomes are published in the Control Health Dashboard (CHD) record CHD-SEC-ASAP-Q1-2026, with underlying test scripts and evidence references archived per RR-17 retention requirements. GRC also convenes cross-functional policy working groups when significant changes to the ecosystem are proposed.

Internal Audit acts as the independent assurance function. Audit's responsibilities include evaluating design effectiveness, operational effectiveness, and sustainability of the control environment described herein. The most recent audit plan entry AUD-IT-2026-020 includes an end-to-end review of artifact signing and attestation across two major platforms, with fieldwork scheduled for 2026-07 and reporting in 2026-08. Management responses to audit observations will be tracked via the Management Action Plan system (MAP-SEC-2026-07-xx series) with due dates and ownership clearly assigned.

Finally, the Enterprise Change Advisory Board (eCAB) ensures that changes materially affecting signing and attestation controls are reviewed for operational risk and approved with traceable evidence. eCAB ensures that dependencies across SBS, CPE, PKI Services, and consuming platforms are coordinated, and that rollouts proceed within resourced maintenance windows. eCAB meeting records (e.g., eCAB-2026-04-18-Agenda Item 6) indicate consistent attendance from all accountable teams and document approvals with associated risk notes and backout considerations for traceability.

4. Governance and Oversight

Governance for artifact signing and attestation is anchored in the Information Security Management System and operationalized through defined committees, review cadences, and evidence repositories. The Security Architecture Review Board (SARB) provides design-time oversight by evaluating proposed changes to signing formats, trust policy, and attestation schemas. SARB findings must articulate impacts on control objectives and downstream verifiers, with decisions recorded against design dossiers. The SARB session on 2026-02-06 (minutes SARB-2026-02-06-Item3) endorsed the consolidation of attestation fields for supply chain transparency, contingent upon demonstrable telemetry coverage within the Continuous Compliance Telemetry Lake (CCTL).

Operational oversight is delivered by the Enterprise Change Advisory Board (eCAB), which validates readiness prior to any production-affecting changes to MBF, MAR, ESS, or verifiers embedded in runtime platforms. eCAB requires that change records include clear references to performance baselines, regression test outcomes, and rollback preparedness. During 2026-Q1, eCAB reviewed and approved CHG-ESS-2026-02-041 (signature validation performance enhancements) and CHG-MAR-2026-03-019 (repository metadata hardening), each with post-implementation reviews filed within five business days and appended to the Service Management knowledge base for cross-team awareness.

Risk governance is exercised by the Technology Risk Committee (TRC), which receives monthly Key Risk Indicator (KRI) summaries and quarterly deep-dive analyses. KRI definitions for this control family include signature coverage rate across in-scope artifacts, attestation completeness at release gates, median verification latency in deployment pipelines, and policy decision error rates in consuming platforms. Q1-2026 results (TRC pack TRC-SEC-2026-Q1) observed a signature coverage rate of 98.4% across origin artifacts, with a remediation plan underway for the residual gap tied to two legacy data integration workflows (tracked under ARTS-LEG-231 and ARTS-LEG-232). Attestation completeness averaged 96.1%, with variance noted during a supplier onboarding change (VRM tracking note VRM-INTK-6013). Verification latency remained within objectives (p50: 420 ms; p95: 780 ms) as recorded in SLO-SBS-ESS-2026.

Evidence governance is consolidated in the Evidence Repository and the CCTL, which together serve as the system of record for audit and regulatory inquiries. Evidence packages created for releases link signatures, verification results, attestation manifests, and associated change records through globally unique identifiers (GUIDs) recorded in both the release orchestration system and the repository index. The Evidence Indexer (EVX) service maintains referential integrity and completeness checks, with daily completion summaries published to Ops channel #sbs-evidence (Ops digest OPS-DIG-2026-04-15T06:30Z). Evidence retention aligns with RR-17 under FIN-REC-07 and is reconciled quarterly by Records Management and GRC (reconciliation ticket REC-GRC-2026-Q1-004).

Independent assurance is delivered through scheduled control testing and thematic reviews. GRC conducts semi-annual control design reviews to ensure alignment with evolving standards and threat models, with outcomes documented in GRC-REV-SEC-ASAP-2026-H1. Additionally, Internal Audit's planned engagement AUD-IT-2026-020 will evaluate the integrity of trust anchor governance, verification controls at deployment, and evidence sufficiency for SOX ITGC reliance. Preliminary scoping meetings (2026-04-12T14:00:00Z) confirmed data availability via the CCTL query interface and Evidence Repository APIs, with audit data pull authorizations recorded in Access Request AR-IA-2026-041.

The Governance Office tracks the maturity of artifact signing and attestation capabilities as part of the enterprise security capability model. Maturity indicators encompass process standardization, automation coverage, telemetry quality, and third-party assertion ingestion. The 2026 Capability Maturity Assessment (CMA-SEC-2026-01) rated the domain at Level 3 (Defined), with a glidepath to Level 4 (Managed) contingent upon completion of automated

attestation policy enforcement in all runtime platforms and universal ingestion of supplier attestations via standardized exchange formats. Program increments for these objectives are captured in the Transformation Roadmap (TMO-SEC-TR-2026) with checkpoints scheduled at the end of each quarter.

Oversight includes systematic management reporting and transparent remediation tracking. Management dashboards provide drill-down views by business unit, artifact type, and environment, enabling executives to assess adoption, control effectiveness, and operational headroom. The Q1-2026 Executive Summary (EXSUM-SEC-ASAP-Q1-2026) highlighted three themes: sustained signature coverage exceeding 98%, targeted remediation of legacy pipelines, and increased onboarding of third-party attestations. Remediation tasks are governed under standard work items with due dates and accountable owners (e.g., WIT-LEGACY-ATT-009 due 2026-06-15, owner: Global Markets Technology DevSecOps Lead), with weekly status reviews documented in Program Sync logs.

Governance also extends to supplier ecosystems. Vendor Risk Management (VRM) coordinates with Security Architecture and Procurement to embed attestation deliverables and signature requirements into contracts and Statements of Work for software suppliers. The Supplier Assurance Program (SAP-SEC-2026) defines evidence formats, intake verification checkpoints, and performance expectations for suppliers. In Q1-2026, 14 strategic suppliers completed onboarding to attestation exchange endpoints, with intake effectiveness reflected in the KRI trendline (VRM report VRM-SUPP-2026-Q1). Deviations detected at intake are recorded as Supplier Conformance Findings (SCF) and remediated through VRM action plans, with summary outcomes fed into the quarterly TRC review.

5. Metrics and Reporting

Metrics under this policy emphasize coverage, quality, timeliness, and resilience. Coverage metrics include the proportion of in-scope artifacts signed at source, the proportion verified at the point of deployment, and the percentage of releases accompanied by complete attestation bundles. Quality metrics assess the rate of verification warnings, attestation schema conformity, and SBOM completeness as observed in pipeline telemetry. Timeliness metrics capture median and tail verification latency, mean time to remediate attestation gaps identified at release, and supplier intake lead times. Resilience metrics evaluate service availability for ESS and MAR, as well as the rate of transient verification errors correlated with platform incidents.

Data sourcing for these metrics is standardized. Pipeline events and verification outcomes are streamed into the Continuous Compliance Telemetry Lake (CCTL), where data contracts ensure consistent field definitions across teams. Metrics are computed daily, with weekly and monthly aggregations used for governance reporting. The Metrics Definition Catalog (MDC-SEC-ASAP-2026, rev 1.7) provides canonical definitions, acceptable data quality thresholds, and lineage references to underlying telemetry topics. Data quality monitoring is performed by the Platform Analytics team, which publishes a weekly data health scorecard (ANL-DHS-2026-Week15) and opens corrective tickets when anomalies are detected (e.g., DATA-QUAL-2026-04-112, opened 2026-04-08T09:18:40Z).

Q1-2026 operational metrics indicate sustained adherence to targets. Signature coverage at source averaged 98.4% across 46,213 build artifacts, with four segments below target attributable to legacy integration paths pending modernization (ref. ARTS-LEG-231/232). Deployment verification occurred for 99.1% of promoted releases, with the remainder accounted for by controlled maintenance updates that bundled no code changes but triggered pipeline steps--these events were correctly flagged by policy engines and queued for review, then cleared without incident. Attestation completeness averaged 96.1%, with most gaps resolved within 2.4 business days median time-to-remediate, as reported in CHD-SEC-ASAP-Q1-2026.

Service reliability metrics remained within objectives. ESS availability measured 99.98% for the quarter (two brief partial degradations; incidents INC-ESS-2026-02-087 and INC-ESS-2026-03-219), with both events resolved within the established service restoration targets. Verification latency at deployment gates met performance standards (p50: 420

ms; p95: 780 ms), preserving throughput in continuous delivery pipelines. MAR sustained consistent metadata delivery with zero integrity exceptions reported.

Reporting is issued through multiple channels to ensure stakeholder alignment. Operational scorecards are distributed weekly to SBS, CPE, and DevSecOps leads (distribution list sec-asap-ops@meridian), while monthly KRI packs are provided to TRC and the Chief Information Security Officer (CISO). Quarterly executive summaries consolidate performance, risks, and forward actions, with traceable references to underlying evidence sets. All reports carry stable identifiers, timestamps, and data lineage annotations; for example, EXSUM-SEC-ASAP-Q1-2026 includes lineage markers to CCTL datasets CCTL.ds.sign.verify.v1 and CCTL.ds.attest.bundle.v2.

Where metrics identify sustained variance, management action plans are initiated with defined owners, target dates, and interim checkpoints. Progress is reviewed in the Engineering Risk Forum (ERF) and escalated to TRC as needed. During Q1-2026, two management actions were initiated to address attestation gap hotspots in legacy workflows (MAP-SEC-2026-07 and MAP-SEC-2026-08), both on track as of 2026-04-12T17:05:11Z. No material weaknesses or significant deficiencies were reported, and existing controls remained suitable for SOX ITGC reliance, pending confirmation by Internal Audit upon completion of AUD-IT-2026-020.

All metrics and reports are subject to periodic validation to ensure that definitions, thresholds, and data pipelines continue to reflect the policy's intent and regulatory expectations. Adjustments to metric definitions follow the governance path of SARB review and eCAB approval, with change notes appended to MDC-SEC-ASAP-2026 and communicated to stakeholders via the monthly governance bulletin (GOV-BLTN-2026-04-Edition).

Page 5

Section 5 -- Control Governance, Ownership, and Change Authority

Meridian Capital establishes centralized governance for artifact signing and attestation under the Office of the CISO, with delegated day-to-day ownership to Secure Build Services (SBS) and Identity & Key Management (IKM). Control authority is documented in the GRC system of record (RiskTrack) under control families AC-SIGN-01 (Artifact Signing), AC-ATTEST-02 (Build Attestation), and AC-VERIFY-03 (Verification Gatekeeping). The definitive mapping of services and repositories to these controls is maintained by Cloud Platform Engineering (CPE) through the Service Inventory Registry (SIR-Prod), refreshed nightly at 02:30 UTC. As of 2026-06-30T00:00:00Z, the accountable control owner for AC-SIGN-01 is the Director, SBS (owner ID: OWN-4821), and the responsible engineering managers are designated per portfolio in tickets MCSEC-2026-11234 and CPE-OPS-2026-5507.

Executive sponsorship is provided by the Deputy CISO for Platform Security, who chairs the monthly Control Health Review (CHR) spanning SBS, IKM, CPE, Risk & Controls (R&C), Internal Audit, and Enterprise Architecture. Quorum is required (minimum four distinct director-level participants), and meeting minutes, attendance, and action items are filed under the collaboration workspace folder Ref: CHR/Signing/2026 with immutable hash anchors recorded in the Document Integrity Ledger (DIL). The CHR agenda consistently includes: control coverage metrics by service tier; change calendar review; nonconformance analysis; attestations lifecycle KPIs; and open risks with target remediation dates. CHR-2026-06 (held 2026-06-18T14:00:00Z) closed three action items: (1) updating the Tier 2 service onboarding checklist to reflect revised attestation schema v1.3 (SBS-ENG-2026-2099), (2) confirming completion of key rotation attestations for EU-region build pools (IKM-2026-4411), and (3) adding verification gate telemetry to the Control Health Dashboard (CPE-OBS-2026-771).

Change management for signing and attestation controls follows Enterprise RFC process (CAB-Standard), with SBS as the default change owner. Any material modification to signing infrastructure, attestation schemas, verification policies, or gate enforcement thresholds must be introduced via RFC with documented rollback, dependency mapping, and regression validation. Routine maintenance (e.g., non-breaking library updates, build runner patching) is executed under MMR (Minor Maintenance Release) tickets linked to a parent CAB record. For Q3 FY2026, RFC-CAB-2026-1817 covered the introduction of attestation schema v1.3 and verification engine enhancements; pilot validation was performed in non-production build pools BP-NP-07/08 between 2026-06-05T09:00:00Z and 2026-06-10T22:00:00Z, with success criteria met and sign-off captured from SBS, IKM, and CPE. No emergency changes are permitted for signing keys or policy definitions; where urgent mitigations are required, deployments are deferred or blocked until a standard CAB-approved change is completed.

Ownership boundaries are explicit and enforce separation of duties. SBS operates the signing and attestation services and maintains the verification gate in the CI/CD control plane. IKM manages key material lifecycle, including provisioning, rotation, and archival in FIPS-validated modules, and enforces administrative access controls. CPE ensures integration of policy gates across deployment orchestrators and maintains telemetry exports to the enterprise observability stack. R&C performs quarterly control testing and assures alignment with regulatory control frameworks (e.g., SOC 2, ISO/IEC 27001 control mappings as documented in R&C-MAP-2026-07). Internal Audit independently evaluates control design and effectiveness at least annually; the most recent audit cycle (IA-2026-014) recorded effective ratings for design and operating effectiveness with follow-up recommendations limited to documentation clarity for service-specific onboarding checklists.

Escalations follow a 24x7 model. Control degradations detected by health monitors initiate incident tickets in the Operational Risk queue (OPRISK) and page the SBS on-call via the Enterprise Pager roster (rotation SBS-OC-PRD, weekly handoffs Monday 08:00 local). Example: OPRISK-2026-3019 was raised at 2026-05-27T03:11:42Z for elevated attestation retrieval latencies exceeding the defined threshold in the EU-West region; the issue was triaged and

resolved within the target service level with no policy downgrades or gate bypasses. If any degradation could lead to unsigned or unverified artifacts progressing, the gates default to block and a business-impact assessment is performed by the affected service owners alongside SBS and R&C. Deviations are not authorized; remediation is required prior to progression. Status communications follow the standard incident communications protocol and are archived in the incident repository with cross-links to supporting telemetry captures.

No ad hoc overrides are permitted. Temporary accommodations such as manual attestations, key substitutions, or selective disabling of verification rules are prohibited. Where development timelines require earlier integration, project plans must reflect onboarding to the control framework as an entry criterion. The "Ready for Build Promotion" milestone in the Enterprise Delivery Framework (EDF) explicitly includes verification of signing and attestation readiness; gating is enforced by the CI/CD control plane. The Dev Enablement team maintains adoption guides and FAQs on the Developer Portal (Doc IDs DEV-SEC-SIGN-101 through -110) and tracks onboarding via the Product Security Readiness Kanban (PSRK). As of 2026-06-30, 97% of active product teams have fully integrated the verification gate at all required stages; remaining teams (tracked in PSRK-2026-Backlog items 55, 72, and 81) have committed remediation plans with dates approved by their respective VPs of Engineering.

Risk acceptance is out of scope for this control; if a service cannot meet requirements, deployment is halted and remediation plans are executed. R&C maintains a watchlist of services approaching control deadlines and coordinates with Portfolio Risk Managers to ensure delivery plans include necessary technical work. Where architectural constraints are material, the Architecture Review Board (ARB) must be engaged to align service design to policy rather than requesting policy exceptions. All decisions, minutes, and supporting documents are retained under the DIL anchor scheme to preserve auditability and chain of custody.

Page 6

Section 6 -- Monitoring, Metrics, Reporting, and Audit Readiness

Control health is continuously assessed through telemetry captured at signing, attestation publication, and verification points. The Control Health Dashboard (CHD), maintained by CPE Observability, aggregates indicators including: proportion of artifacts signed per release train; attestation generation success rates; verification gate pass/fail counts; median and p95 attestation retrieval latency; and attestation schema compliance. Data sources are normalized into the Enterprise Metrics Bus (EMB) with entity keys aligned to SIR-Prod service identifiers. As of the June 2026 reporting cycle (report REF: CHD-2026-06, generated 2026-06-29T23:50:00Z), Tier 0/1 services achieved 100% signed artifacts with 100% retrievable attestations, and Tier 2/3 services averaged 99.6% signed artifacts with 99.4% retrievable attestations. Attestation retrieval p95 latency remained within target, measured at 410ms in NA-East, 460ms in EU-West, and 505ms in AP-Southeast.

Key performance indicators and thresholds are defined and reviewed quarterly:

- Signature Coverage: 100% for Tier 0/1, >=99.5% for Tier 2/3. Measured at release completion and post-deployment verification.
- Attestation Availability: >=99.9% within 60 seconds of artifact indexing for Tier 0/1, and within 120 seconds for Tier 2/3.
- Verification Gate Efficacy: False-negative rate of zero, false-positive rate <=0.05% of gate decisions per month.
- Mean Time to Detect (MTTD) Attestation Mismatch: <=5 minutes from publication to detection.
- Mean Time to Restore (MTTR) Control Degradation: <=4 hours for Tier 0/1 impacting events; <=8 hours for Tier 2/3.

Performance against these thresholds is summarized in the monthly Control Performance Report (CPR). CPR-2026-06 recorded no Tier 0/1 threshold breaches. Two Tier 2/3 services missed the attestation availability objective for a single release window due to dependent storage replication delays; both were contained by gate blocks, with remediation tracked in SBS-ENG-2026-2231 and CPE-OPS-2026-5793. No artifacts advanced without successful verification, and post-incident reviews confirmed monitoring sensitivity and alert routing functioned as designed.

Evidence generation for audit readiness is automated. For each release, a Release Evidence Package (REP) is compiled, containing: artifact manifest with checksums; signing event metadata (timestamp, signer service ID, key reference alias); attestation document references with integrity hashes; verification gate result logs; and control oversight approvals where applicable (e.g., CHR acknowledgment for schema migrations). REPs are stored in the Evidence Vault with seven-year retention, WORM protection enabled, and DIL anchors to support non-repudiation. Internal Audit has read-only access to REPs via the Audit Portal, with search parameters scoped by service, time window, and control ID. During IA-2026-014 sampling, auditors retrieved REPs for 25 releases across three regions without assistance and validated completeness against the audit program steps (AUD-PGM-2026-014-S8).

Continuous control testing (CCT) is performed by R&C and SBS. Synthetic validation jobs run hourly across representative pipelines to confirm: signing invocation occurs; attestations are generated using the current approved schema; and verification gates block on expected failure modes. Results are logged under the CCT dataset with pass/fail and latency histograms. June 2026 CCT stats showed 99.98% pass rate across 2,160 runs; three failures in AP-Southeast were linked to a transient dependency timeout, already addressed in CPE-OBS-2026-812. Quarterly, R&C executes design-effectiveness walk-throughs and operating-effectiveness re-performance of controls, with outputs documented in RNC-TEST-2026-Q2. Findings for Q2 included a recommendation to enhance the homepage of the CHD with contextual explanations for threshold changes; SBS applied the improvement under DEV-PORTAL-2026-141

by 2026-06-25T18:22:07Z.

Reporting obligations include consolidated summaries to the Technology Risk Committee (TRC). The TRC briefing pack (TRC-BR-2026-07) includes a one-page dashboard view, material incidents since the prior meeting, adoption trajectory by service tier, and a preview of upcoming change windows with risk commentary. The July pack highlights completion of schema v1.3 rollout, stabilization of retrieval latency in APAC regions, and an ongoing initiative to standardize attestation producers across legacy build pools. Risk statements are aligned to the enterprise risk taxonomy, with inherent and residual ratings validated by Portfolio Risk Managers.

Training and access oversight underpin measurement reliability. SBS and IKM engineers with administrative responsibilities complete annual control-specific training (LMS course SEC-PLT-204) and quarterly reviews of privileged access (IKM-AAR-2026-Q2). Access reviews conducted 2026-06-12T10:00:00Z confirmed least-privilege for all named administrators and removal of two stale service accounts (IAM-OPS-2026-332). Changes to monitoring thresholds or report definitions require dual approval from SBS and R&C, logged in change tickets and recorded in the CHD changelog (CHD-CHNG-LOG entries 2026-06-07#14 and 2026-06-21#03).

Disaster recovery and continuity targets for monitoring and evidence systems are defined to maintain auditability. The CHD and Evidence Vault maintain regional redundancy with documented RTO of 4 hours and RPO of 15 minutes. DR exercises executed 2026-05-14T02:00:00Z (exercise ID DR-CHD-2026-05) demonstrated recovery within targets, with after-action items limited to dashboard cache warming optimization (CPE-OBS-2026-799). Quarterly, SBS validates that DIL anchors reconcile after failover and that evidence record integrity remains intact, with reconciliations documented in SBS-CTRL-REC-2026-Q2.

Third-party and open-source dependencies are included in metrics and reporting through supplier attestations and SBOM ingestion. Supplier attestations are validated at intake and linked to internal REPs, with verification outcomes visible in CHD. Where supplier attestations are delayed or incomplete, gates retain default-block posture until artifacts are fully verified. Supplier Management tracks these events in SUP-MGMT-2026-119; June metrics indicate 100% compliance among strategic suppliers and 98.7% among long-tail vendors, with remediation plans active for the remainder.

Collectively, these monitoring, metrics, and reporting practices ensure the Artifact Signing and Attestation Policy is measurable, transparent, and auditable, and that deviations are promptly detected, contained by default controls, and remediated within defined service levels.

Page 7 -- Operational Monitoring, Metrics, and Telemetry

1. Overview

Meridian Capital maintains continuous observability over artifact signing and attestation activities to provide defensible, real-time assurance of software integrity across build, test, and deployment pipelines. The Software Supply Chain Security (SSCS) team, in partnership with DevSecOps Platform Engineering and Identity & Key Management (IKM), operates the centralized telemetry plane and analytic dashboards that support policy enforcement and executive reporting. Monitoring extends to all CI/CD orchestrators in scope, container registries, binary repositories, and deployment control points for Tier 1 and Tier 2 applications as designated by the Enterprise Application Inventory (EAI). All monitoring implementations and data schemas are managed as code and governed through the Change Advisory Board (CAB) per change records categorized under "S-SIGN-OBS" classification.

2. Instrumentation and Event Taxonomy

The attestation verification service (internal service code: Aegis-Verify) and the signing service (internal service code: Aegis-Sign) emit normalized, structured events with the following canonical categories:

- SEC-LOG-ATT-VERIFY: Attestation verification outcomes, including signature validation state, subject digest, and policy gate decision.
- SEC-LOG-ATT-ISSUE: Attestation issuance events with provenance references, build context identifiers, and policy mappings.
- SEC-LOG-SIGN-KEY-USE: Key usage telemetry, including non-sensitive key IDs, rotation epochs, and mTLS client identity references.
- SEC-LOG-POLICY-EVAL: Policy engine rule set evaluations and decision traces (hash-linked to rule set version).
- SEC-LOG-REGISTRY-GATE: Deployment registry admission and deny events at promotion boundaries (dev->test->prod) with associated artifact metadata.

All events are stamped in UTC and include consistent field names aligned to the SSCS Observability Contract v2.8 (schema ID: MC-SSCS-OBC-2_8), effective 2026-03-31. As of 2026-06-30, endpoints are integrated with Splunk index "sec_artifact_attest_v3" and long-term archival in the enterprise data lake partition "dlake_sec_schain_attest" (partitioned by region and week). The schema is subject to change control via JIRA epic SEC-OPS-PLAT-432, with CAB approval required for field additions or phase-outs to avoid downstream analytic breaks.

3. Dashboards and Operational Views

The Artifact Trust Posture Dashboard (version 3.4.2) is the primary operational view for SSCS analysts and product teams. It comprises:

- Attestation Coverage Rate: Proportion of release-bound artifacts with valid attestations at time of promotion.
- Signature Freshness Compliance: Percentage of attestations issued within the defined freshness window prior to deploy.
- Verification Latency: Median and P95 verification times across pipelines and environments.
- Policy Denial Rate: Rate of deployment gate denials attributable to missing or non-conforming attestations.
- Provenance Completeness: Percentage of attestations that include all mandatory provenance claims (build system ID, source repository reference, actor identity, and immutable artifact digest).

Quarterly dashboard integrity reviews are captured under ServiceNow task MC-SSEC-2026-1774 (closed 2026-06-24T09:12:46Z, SSCS Analytics), verifying alignment with the schema contract and confirming alert routing correctness to the on-call rotations (PagerDuty service keys redacted).

4. Service-Level Objectives and Current Performance

The following SLOs are approved per CAB change MC-CAB-2026-241 for the current fiscal year:

- Availability SLO (Aegis-Sign): 99.95% monthly, measured by successful signing requests across primary and failover zones.
- Availability SLO (Aegis-Verify): 99.99% monthly, measured by successful verification responses within latency objectives.
- Latency Objective (Verify): Target median <= 250 ms; P95 <= 600 ms across Tier 1 environments.
- Attestation Coverage Target: >= 99.5% for Tier 1 deployable artifacts; >= 98.0% for Tier 2.
- Policy Denial Rate Benchmark: <= 0.35% per 10,000 deployment attempts, with root-cause analysis for any daily spike >= 0.75%.

Q2 FY2026 performance outcomes (report run 2026-06-30T18:03:27Z, dashboard snapshot ID: DSH-ATT-3435):

- Aegis-Sign availability: 99.963% (within SLO).
- Aegis-Verify availability: 99.992% (within SLO).
- Verification latency: Median 212 ms; P95 528 ms (within target).
- Attestation coverage (Tier 1): 99.71%; (Tier 2): 98.64% (meet/exceed targets).
- Policy denial rate: 0.28% per 10,000 deployments (no corrective action triggered).

5. Alerting and Operational Response

Metrics-driven alerts are configured to page the SSCS on-call for coverage dips, sustained latency breaches, or anomalous denial rate spikes. Example detections include:

- Coverage Regression Detector (rule ID: ATT-COV-DET-07) triggered if rolling 4-hour coverage in a Tier 1 pipeline declines by >= 0.3 percentage points versus 14-day baseline.
- Denial Rate Anomaly (rule ID: ATT-POL-ANOM-03) triggered by a 3-sigma deviation on a per-application basis.

All alerts carry correlation IDs to facilitate triage across signing, verification, and registry gate logs. During Q2 FY2026, one minor alert sequence (INC-SSEC-2026-0619) occurred on 2026-06-19T14:22:14Z due to a transient schema ingestion lag in the staging environment following a planned analytics node upgrade (Change CRQ00048291). No attestations were lost; event processing caught up within 17 minutes. Root cause and corrective actions were documented in JIRA SEC-OPS-3641 (closed 2026-06-21T11:05:10Z), with a data pipeline back-pressure threshold adjustment approved by CAB under MC-CAB-2026-255.

6. Data Quality Assurance

Data completeness, correctness, and timeliness are attested monthly via automated checks and sampling reviews:

- Completeness: Cross-check of issuance and verification event counts per artifact digest (tolerance <= 0.1% differential).
- Correctness: Schema validation against MC-SSCS-OBC-2_8; non-conformant records quarantined for reprocessing and tracked in SEC-OPS-ETL-1179.
- Timeliness: 99% of verification events available in Splunk within 120 seconds of occurrence; alerts fire for sustained degradations.

The June 2026 data quality report (RPT-SSEC-DQ-2026-06) recorded 99.92% completeness, 99.997% schema conformance, and 99.4% timeliness compliance. A minor variance in completeness (0.08%) was traced to a controlled blue/green deployment test of Aegis-Verify (CRQ00048374); reconciled within the measurement window.

7. Access and Segregation of Duties

Observability data is classified as Confidential-Controlled. Role-based access is enforced via enterprise IAM, with least-privilege read entitlements for product teams (role: sscs_attest_ro) and elevated investigative roles for SSCS analysts (role: sscs_attest_rw). Write access to dashboards and alert configurations is restricted to SSCS Analytics Engineering (group: sscs-obs-admins) and is reviewed quarterly (last review: 2026-06-28T15:36:02Z; ticket: IAM-REV-2026-ATT-0025). No anomalous access patterns were observed; audit events are retained per the Records Retention section and are discoverable for regulatory and internal investigations.

Page 8 -- Auditability, Evidence Management, and Governance Reviews

1. Audit Evidence Model and Control Mapping

Meridian Capital's Artifact Signing and Attestation Policy is mapped to the enterprise control framework and aligned with external standards where applicable. The authoritative control mappings are maintained in the GRC platform (record set: GRC-SSCS-CTRL-SET-11, last updated 2026-06-12T10:49:58Z, Information Risk Management). Key internal controls include:

- MC-SSCS-01: All production-bound artifacts must carry a valid, policy-conformant attestation verified at promotion time.
- MC-SSCS-02: Signing and verification services must enforce strong, centrally managed identities and record non-sensitive key usage telemetry.
- MC-SSCS-03: Attestation and signing events must be logged with integrity-protected, time-synchronized records and retained per policy.
- MC-SSCS-04: Changes to signing, verification, and policy engines must follow CAB governance with documented testing and rollback plans.
- MC-SSCS-05: Quarterly reviews must assess attestation coverage, provenance completeness, and adherence to segregation-of-duties principles.

Evidence artifacts supporting these controls are curated in the "SSCS Evidence Locker" within the GRC repository (folder ID: EV-SSCS-2026-Q2). Artifacts include signed dashboard exports, attestation policy manifests (hash-referenced), CAB approvals, and sampling trace packages for selected applications. Evidence index entries contain immutable hashes and retention tags linked to case IDs for traceability.

2. Quarterly Control Review and Sampling

The Q2 FY2026 control review was conducted by Information Risk Management (IRM) with SSCS and DevSecOps participation under audit case IRM-AUD-ATT-2026-Q2. Fieldwork occurred between 2026-06-17 and 2026-06-21, culminating in the issuance of the review memo on 2026-06-24T13:08:33Z. The sampling methodology applied a risk-weighted approach:

- Population: 12,842 production-bound artifacts across Tier 1 and Tier 2 applications.
- Sample: 148 artifacts for detailed trace review (confidence 95%, margin +/-7.5% on target metrics), stratified by environment, pipeline technology, and business unit.

Review Procedures (high level):

- Confirmed presence and validity of attestations at the time of last promotion via registry gate logs.
- Verified provenance completeness claims and cross-referenced source repository commit identifiers with build metadata.
- Assessed policy engine rule set versions against CAB-approved baselines for the sampling window.
- Validated SoD by confirming that sign-off approvers did not hold administrative rights in the associated build runners.

Results:

- Attestation Coverage: 100% in sample (meets MC-SSCS-01).
- Provenance Completeness: 147/148 complete; one record had a non-critical display label mismatch in the repository reference that did not affect validation or policy decisioning (tracked under SEC-OPS-UI-908, resolved

2026-06-26T16:20:19Z).

- Policy Baseline Alignment: 100% conformity to rule set versions approved in MC-CAB-2026-235 and MC-CAB-2026-241.
- SoD Compliance: 100%; access review corroborated by IAM attestation report IAM-ATT-RPT-2026-06-20.

3. Findings and Management Responses

The review identified no control deficiencies. Two low-severity observations were recorded to improve operational clarity:

- OBS-2026-ATT-001: Inconsistent naming conventions between dashboard widgets and GRC evidence labels increased reconciliation time during sampling. Management response (SSCS Analytics): Standardized label dictionary proposed under SEC-OPS-PLAT-471; target completion 2026-08-15; CAB change MC-CAB-2026-269 opened for review.
- OBS-2026-ATT-002: Three evidence files for April 2026 lacked embedded snapshot timestamps in PDF footers, although timestamps were present in file metadata. Management response (IRM Coordination): Updated evidence export checklist in GRC SOP-IRM-EL-4.2; action closed 2026-06-29T09:44:02Z.

4. External Dependencies and Third-Party Oversight

Where third-party components or open-source packages enter Meridian Capital's build streams, attestation requirements are enforced at ingress and promotion boundaries in accordance with Third-Party Software Governance Standard (STD-TPSW-5.1). External attestations, where available, are validated against trust policies anchored to enterprise-approved certificate authorities and metadata claims sufficient to establish provenance. When external attestations are absent or non-aligned with policy, the artifact undergoes enhanced review, including heightened provenance corroboration through repository metadata and supplier documentation. All third-party trust decisions are documented within the Supplier Risk Module (SRM) under case IDs linked to the consuming application's risk register entry. Q2 FY2026 SRM review sample (SRM-TP-ATT-2026-Q2) recorded 22 third-party packages with complete attestations and 7 undergoing enhanced review; all were cleared for use following successful corroboration steps documented in SRM-DEC-2026-071-097.

5. Records Retention and Legal Hold

Attestation and signing telemetry, including derived analytics and dashboard exports, are retained for a minimum of 24 months in hot storage and a further 60 months in compliant archival, subject to jurisdictional requirements and business unit retention schedules. Legal hold directives supersede standard retention and are applied via the Records Management System (RMS) with immutable tags propagated to the evidence locker and data lake partitions. The most recent legal hold applicability review (RMS-LH-CHK-2026-06, completed 2026-06-27T12:31:47Z) confirmed no changes affecting SSCS data sets.

6. Governance, Training, and Awareness

Annual policy attestation and role-targeted training are mandatory for personnel interacting with build and release tooling, signing/verification services, and GRC evidence processes. The 2026 training cycle (TRN-SSCS-2026-ANNUAL) achieved 99.4% completion across in-scope roles as of 2026-06-30, with remaining completions tracked under HR-LEARN-CHS-21941. Training content aligns with this policy and covers artifact trust principles, evidence handling, and responsibilities related to SoD. Quarterly awareness briefs are issued by SSCS (latest: SSCS-BRIEF-2026-Q2, distributed 2026-06-18T08:05:22Z), highlighting observed trends, metric performance, and upcoming governance changes. Feedback is captured via the Enterprise Feedback Tool (EFT case series EFT-SSCS-2026-112-134) and informs the continuous improvement backlog.

7. Continuous Improvement and Roadmap

SSCS maintains a rolling, prioritized backlog for enhancements to attestation coverage, evidence automation, and analytics capabilities. Current items include:

- Automated Evidence Packaging v2 (SEC-OPS-PLAT-489): One-click generation of complete sampling packets with embedded timestamps and cross-links; pilot planned for 2026-08.
- Provenance Schema Extension (SEC-OPS-SCHEMA-203): Optional claims for build runner attestation references to improve traceability; under CAB review MC-CAB-2026-272.
- Metric Normalization Initiative (SEC-OPS-MET-156): Harmonize coverage definitions across heterogeneous pipelines to simplify cross-portfolio comparisons; target Q3 FY2026 completion.

Progress is reported monthly to the Technology Risk Steering Committee (TRSC). The 2026-06 status (meeting minutes TRSC-MIN-2026-06-25) reflects on-track delivery and no resource constraints. No policy waivers or exceptions were requested or granted during the period; all activities remained within approved governance parameters.

12. Monitoring, Measurement, and Continuous Assurance

Meridian Capital maintains a continuous assurance program to validate that artifact signing and attestation activities perform reliably, at scale, and in conformance with policy intent. The objective is to deliver measurable confidence that every promotable build artifact is signed by an approved organizational key, attested with verifiable provenance and supply chain metadata, and verified at enforcement gates prior to deployment. This section defines the monitoring framework, the key performance indicators (KPIs) used for management oversight, the reporting cadence, and the feedback mechanisms by which the enterprise iteratively improves the control environment.

12.1 Control Objectives and KPIs

Control objectives for the Artifact Signing and Attestation Policy are expressed as service and conformance targets that can be continuously observed and trended. The current KPI set, owned jointly by DevSecOps Engineering and Platform Assurance, is as follows:

- Signing Coverage: Percentage of release-eligible artifacts that carry a valid organizational signature at the time of promotion decision. Target: 99.5%, minimum acceptable: 99.0%.
- Attestation Completeness: Percentage of promotion decisions accompanied by a verifiable attestation bundle including provenance, build recipe references, and policy evaluation verdict. Target: 99.5%, minimum acceptable: 99.0%.
- Verification Gate Efficacy: Percentage of enforcement gate decisions that correctly accept compliant artifacts and reject non-compliant artifacts without manual rework. Target: 99.9%, minimum acceptable: 99.7%.
- Control Latency: Median and 95th percentile time from artifact availability to signed and attested status, measured per pipeline tier. Target: median <= 120 seconds; P95 <= 300 seconds.
- Rotation Timeliness: Completion of planned key rotation tasks within the approved change window. Target: 100%.
- Evidence Integrity: Percentage of required evidence elements (signature references, attestation digests, gate decision logs) written to the immutable evidence store within 15 minutes of event occurrence. Target: 99.9%.

12.2 Data Sources and Telemetry

Monitoring is derived from corroborated signals emitted by the CI/CD controllers, the signing service orchestration layer, the key management control plane, the attestation repository, and the enterprise logging platform. Telemetry is standardized to a normalized event schema that includes artifact digest, signature subject, attestation identifier, build pipeline identifier, and decision outcome. Cross-system correlation is performed using a deterministic artifact correlation key. All timestamps are recorded in UTC with synchronized clock sources. Platform Assurance validates ingestion completeness daily by reconciling aggregate counts for "build finalized," "signature created," "attestation published," and "gate verified" events.

12.3 Reporting Cadence and Consumers

KPI dashboards are refreshed continuously, with daily snapshots available to operational teams and a formal monthly KPI pack distributed to the Architecture Risk Steering Committee, Corporate Risk Office, and Technology Controls Oversight. The monthly pack includes a narrative on trends, outliers, remediations, and forward actions. Distribution for the June 2026 period occurred at 2026-07-02T14:00:00Z, documented under Portfolio Governance record GOV-ARSC-2026-06. Attendance included representatives from DevSecOps Engineering, Cloud Platform Operations, and Line of Business CTO offices. Action items from this session were logged as SVC-ASSURE-3319 (optimize evidence pipeline buffering), PLAT-OPS-7763 (expand signer pool capacity for end-of-quarter peaks), and

RISK-CTRL-1490 (finalize KPI definition for attestation freshness).

12.4 June 2026 Metrics Summary

For the period 2026-06-01 through 2026-06-30, signing coverage averaged 98.7% across all lines of business, with a week-over-week improvement to 99.2% by month end. Shortfall analysis identified two principal drivers: pipeline migrations still onboarding to centralized signing (ART-SIGN-4217) and a transient approval backlog associated with a scheduled maintenance event (CHG-SEC-2026-0617). Attestation completeness tracked at 99.1% average, with gaps concentrated in a single legacy batch pipeline, now remediated via pattern standardization (ENG-PLAT-5592 closed 2026-06-28T10:12:33Z). Verification gate efficacy remained within target at 99.95% with no material misroutes reported by Runtime Policy Enforcement. Control latency met targets in all tiers except nightly imports for Analytics Platform where P95 reached 328 seconds on 2026-06-13 due to controlled throttling; corrective auto-scaling rules have since been tuned (OPS-CAP-2045).

Evidence integrity sustained 100% for the period, confirmed by reconciliation jobs sigsvc-evt-2026-06-30-000232 through -000241. Rotation timeliness posted 100% with completion of Q2 planned rotations (KMS-ROT-2026-Q2) during the approved 2026-06-21 window. The KPI pack documents that all deviations were operational in nature and resolved without impact to promotion decisions. No policy waivers or deviations were requested or granted, consistent with the non-exception posture of this policy.

12.5 Control Testing and Quality Assurance

Platform Assurance executed a statistically significant sample review of 260 promotion decisions across business units, verifying presence and validity of signatures, attestations, and enforcement decisions in the evidence store. The sample pass rate was 99.6%. Four documentation findings (minor, documentation-only) were raised to improve consistency of artifact metadata labels in attestation manifests; all were tracked under QA-ATTEST-1182 to -1185 and closed by 2026-07-01T16:47:10Z after rollout of metadata schema guidance. A targeted negative test set validated that unsigned or stale-attestation artifacts were correctly rejected across staging and pre-prod environments, with results logged under TEST-EVID-2026-06-R04.

12.6 Service Reliability and Capacity

The signing service met availability objectives with 99.99% service uptime for June 2026, excluding a planned maintenance window of 18 minutes (CHG-SIG-2026-0622). Median signing request latency was 84 ms, P95 was 190 ms. Verification services sustained median latency of 46 ms and P95 of 110 ms. Capacity headroom remained above 35% across prime trading hours with autoscaling events peaking at 2026-06-27T21:15:23Z. Cloud Platform Operations and DevSecOps Engineering finalized a capacity model for Q3 seasonal peaks, with completion recorded in CAP-PLAN-2026Q3 and a forecast signer pool expansion of 20% by 2026-08-15. Alert thresholds for queue depth and attestation publication lag were reviewed and modestly tightened to improve early warning sensitivity; changes were approved in CAB minutes CAB-2026-06-29, item 7.

The continuous assurance program will persist with monthly KPI reviews, quarterly control testing, and semi-annual independent verification. Any material trend deterioration will trigger a Corrective Action Plan (CAP) with documented ownership, milestones, and closure evidence routed via the Controls Governance workflow.

13. Audit Readiness, Records Management, and Attestation Evidence

Meridian Capital structures artifact signing and attestation controls to be audit-ready at all times. Evidence is produced contemporaneously, retained according to the enterprise records schedule, and organized for efficient retrieval to support internal audit procedures, regulatory examinations, and customer due diligence. This section codifies the evidence catalog, retention requirements, access governance, compliance mappings, and independent assessment practices that sustain continuous audit readiness for the policy domain.

13.1 Evidence Catalog and Retention

The evidence catalog defines the authoritative record for each control assertion. At minimum, the following are maintained:

- Signature Evidence: immutable references to signature metadata, including artifact digest, signer identity, signature timestamp, and verification outcome recorded at enforcement. Stored in the enterprise evidence repository with a seven-year retention.
- Attestation Evidence: provenance statements, build configuration identifiers, policy evaluation results, and attestations of control conformance captured at build completion and re-validated at promotion. Retained for seven years.
- Decision Logs: enforcement gate decisions, including acceptance or rejection rationale and policy version in effect. Retained for seven years.
- Operational Telemetry: service health metrics, alert acknowledgments, and maintenance records relevant to signing and attestation service reliability. Retained for three years.
- Governance Records: approvals, meeting minutes, KPI packs, and change advisories that authorize policy and platform changes. Retained per Corporate Records Management schedule (minimum seven years).

Evidence is written to an append-only storage class with integrity protections, including cryptographic hashing and periodic ledger reconciliation, and is replicated across fault domains for durability. Records subject to legal hold are marked immutable pending disposition guidance from the Office of the General Counsel (ref. LEG-HOLD-2026-044). The Evidence Steward within Platform Assurance is the accountable owner for catalog integrity, with daily completeness checks and monthly reconciliation reported under EVID-RECON-2026 series tickets.

13.2 Access Governance and Segregation of Duties

Access to evidence and signing operations is restricted to defined roles, each assigned on the principle of least privilege with documented approvals through Identity Governance workflows. The following functional roles are in force: Key Custodian (custodial oversight of key lifecycle operations), Signing Service Operator (service reliability and configuration management), Release Approver (promotion decision authority), and Evidence Auditor (read-only access to evidence repositories). No individual may hold conflicting roles that would enable initiation and approval of the same promotion decision. Temporary elevated access is time-bound and subject to supervisory approval, with automated expiration and post-facto review logged under ACCESS-REVIEW-2026 monthly cycles. As of 2026-06-30, all quarterly access certifications for these roles are complete (IGA-CERT-2026-Q2 closed 2026-07-03T09:21:44Z) with zero exceptions noted.

13.3 Compliance Mappings

The policy and its control set map to Meridian Capital's enterprise control framework and external standards relevant to

secure software lifecycle governance. Mappings are curated by Technology Controls Oversight and maintained in the Controls Library (CTL-LIB-SS-ATTEST-v2.3). Representative alignments include lifecycle controls for change management, cryptographic control management, integrity verification, and records retention. These mappings facilitate audit scoping, test planning, and external reporting, and are reviewed semi-annually or upon material control changes.

13.4 Responding to External Requests

Customer due diligence and regulator information requests related to artifact integrity, provenance, and control design are coordinated by the Client Assurance Team with inputs from Platform Assurance and DevSecOps Engineering. Standard response packages include attestation summaries, KPI overviews, independent assessment letters, and policy excerpts. The service-level objective for initial response is five business days, with expedited handling for contractual obligations. All requests are tracked end-to-end in the Client Assurance queue; during Q2 2026, 14 requests were fulfilled (ASSURE-RFI-2026-201 through -214) with an average completion time of 3.7 business days.

13.5 Independent Assessment

Internal Audit completed a focused assessment of artifact signing and attestation controls in Q1 FY26 (IA-ENG-2026-014). Scope included design effectiveness, operational effectiveness, and evidence sufficiency. The assessment concluded "Effective" with two low-severity observations: enhance dashboard drill-through traceability from KPI trend to underlying event (closed DEVSEC-OBS-2026-007 on 2026-05-19T12:55:02Z) and formalize a single reference index for policy evaluation versions (closed GOV-CTRL-2026-031 on 2026-06-07T08:11:27Z). No deficiencies were noted in enforcement gate operation or evidence retention. Internal Audit will re-assess during the annual Technology General Controls cycle in Q1 FY27, or earlier should material changes occur.

13.6 Policy Governance and Change Log

The Artifact Signing and Attestation Policy is governed by the Technology Policy Council and is versioned with formal approvals and recorded effective dates. Version 2.3 was ratified on 2026-07-01T15:00:00Z under Policy Council record TPC-2026-07-01-05 following CAB endorsement (CAB-2026-06-29, item 5). Notable updates included clarification of evidence integrity checks, addition of rotation timeliness KPI, and consolidation of attestation completeness definitions. Implementation guidance documents were updated accordingly (GUID-ATTEST-2026-v2.3). All downstream procedures and runbooks were reviewed by accountable teams with confirmations logged in PROC-ACK-2026-ATTEST series by 2026-07-08.

13.7 Readiness Statement

Based on the current control operation, evidence completeness, and independent assessment outcomes, Meridian Capital affirms audit readiness for artifact signing and attestation controls as of 2026-07-15T00:00:00Z. This readiness statement is contingent on sustained adherence to monitoring thresholds, timely remediation of operational issues, and preservation of records as specified herein. The Policy Owner (Head of DevSecOps Engineering) and the Control Owner (Director, Platform Assurance) are jointly responsible for maintaining this readiness and for notifying the Technology Policy Council of any material change in control performance.

Page 11 -- Artifact Signing and Attestation Policy (Meridian Capital)

11. Monitoring, Measurement, and Key Performance Indicators (KPIs)

Meridian Capital maintains a structured measurement framework to ensure the efficacy, consistency, and timely operation of artifact signing and attestation across all approved build and release pathways. Monitoring focuses on both control effectiveness (e.g., signing occurrence and verification success) and operational health (e.g., job queue latency, attestation issuance throughput). Metrics are curated by the Supply Chain Telemetry Service (SCTS) operated by DevSecOps Engineering (DSE) and continuously reconciled with the Enterprise Key Management Service (EKMS) audit stream and the Release Governance Ledger (RGL) operated by the Software Supply Chain PMO. Each metric is versioned and cataloged with a unique identifier for traceability, and is reviewed in accordance with the Governance Cadence described in Section 13.

The following KPIs are considered control-critical and are tracked at the application, business unit, and enterprise levels:

- Metric ASM-01: Artifact Signing Coverage. Definition: proportion of releasable artifacts that carry a current, policy-aligned digital signature from an approved trust root. Service Level Objective (SLO): >= 99.5% monthly. Rolling 90-day baseline (as of 2026-06-30T23:59:59Z): 99.72%. Measurement Notes: derived from repository event hooks, pipeline manifests, and signature verification receipts; reconciled against permitted artifact types enumerated in Control ASC-07.
- Metric ASM-02: Verification Success Rate. Definition: proportion of signature verifications completed successfully in pre-deploy gates. SLO: >= 99.9% monthly. Rolling 90-day baseline: 99.93%. Measurement Notes: event stream emitted by Gatekeeper-Verify jobs in all CI/CD systems and correlated to Release Ticket IDs.
- Metric ASM-03: Attestation Freshness. Definition: median age (in hours) of attestation documents (SLSA provenance, SBOM attestations) at the time of release promotion. Target: <= 24 hours median; <= 72 hours 95th percentile. Rolling 90-day baseline: 13.4 hours median; 39.7 hours p95.
- Metric ASM-04: Trust Root Alignment. Definition: percentage of signatures anchored to active, approved roots per EKMS Trust Policy TRP-04. SLO: 100%. Rolling 90-day baseline: 100%. Measurement Notes: validated via EKMS Trust Graph version 2026.6.
- Metric ASM-05: Key Lifecycle Compliance. Definition: percentage of signing keys meeting rotation and usage constraints (Control KLC-02). Target: 100%. Rolling 90-day baseline: 100%. Measurement Notes: computed from EKMS key usage logs and CRL deltas.
- Metric ASM-06: Gate Bypass Incidents. Definition: count of release candidates requiring manual governance intervention to reconcile signing or attestation signals. Threshold: 0 per month. Rolling 90-day baseline: 0. Measurement Notes: controlled via Change Tickets; see CHG-2026-05-1419 and CHG-2026-06-0908 for routine gate configuration changes.

SCTS processes and stores metrics on a near-real-time basis (sub-5-minute end-to-end latency target), with canonicalization performed once daily at 02:15:00Z. Dashboards are published to the enterprise observability portal with data sources declared and signed by the telemetry pipeline to prevent tampering. All KPI definitions carry a stewardship assignment; as of 2026-07-01T12:00:00Z, ASM-01 through ASM-06 are stewarded by DSE with Risk, Controls & Compliance (RCC) oversight. Material deviations from SLOs generate alerts in the Security Operations Center (SOC) under event class SCT-ALRT, with escalation paths documented in RCC Playbook RC-PB-19. During Q2 2026, three advisory alerts were generated (TKT: DSE-ALRT-2026-05-1127, DSE-ALRT-2026-06-0203, and DSE-ALRT-2026-06-2711), all closed as non-conformity-avoided events following telemetry tuning; no policy non-conformities were recorded.

12. Auditability, Evidence, and Retention

The policy requires that evidence demonstrating compliant artifact signing and attestation be complete, durable, and independently verifiable. Evidence artifacts include: (a) signed verification receipts for each build and promotion gate; (b) attestation bundles comprising provenance statements and SBOM attestations linked to immutable artifact digests; (c) EKMS key lifecycle logs (creation, use, rotation, and revocation events); and (d) change and approval metadata from the Release Governance Ledger. For each release candidate, the RGL maintains a cryptographic linkset that binds artifact digests, signature envelopes, and attestation identifiers, enabling later reconstruction during audits and investigations.

Evidence must be retained for a minimum of seven (7) years following the last distribution of the associated artifact or for the period prescribed by regulatory retention schedules applicable to the business unit, whichever is longer. Storage must be Write Once Read Many (WORM) compliant and replicated across at least two independent regions under Meridian Capital's standard business continuity tier for regulatory records (BCT-2). The Records & Archives team (R&A) certifies the immutability controls quarterly; attestations for Q2 2026 were completed and recorded under RAA-2026-06-30-IMM, with no deviations. Access to evidence is governed by role-based access control (RBAC) integrated with Identity Governance & Administration (IGA); access requests and approvals are logged and subject to monthly RCC sampling.

Internal Audit may request on-demand evidence packages for scoped reviews. During the Internal Audit thematic review of software supply chain controls (AUD-2026-05-SSCX), the audit team requested and received 45 evidence packages covering April-May 2026 releases across four business units. All packages were delivered within the agreed SLA (5 business days). Two minor documentation completeness findings (AUD-2026-05-SSCX-F12 and F19) were remediated by enhancing receipt bundling in SCTS v2026.6.4 (CHG-2026-06-1205) and updating the RGL export manifest template (RFC-2026-06-1217). No control design or operating effectiveness issues were identified.

13. Reporting and Governance Cadence

Governance reporting is tiered to ensure transparency and timely decision-making:

- Weekly Health Report (operational): DSE circulates a summary of ASM-01 through ASM-06, current alerts, and any active change activities to the Delivery Platform Leads every Monday by 14:00Z (ref: OPS-REP-WSA). Attendance and acknowledgments are captured in the Service Management platform; sample entry for 2026-06-24T14:07:39Z: OPS-REP-WSA-2026-W26.
- Monthly Controls Review (RCC): RCC convenes on the second Wednesday of each month at 16:00Z to review KPI performance, exceptions posture (target remains zero), and any upcoming control improvements. Minutes for 2026-06-12T16:00:00Z are logged under RCC-MIN-2026-06-12 with three actions: refine ASM-03 reporting segmentation, complete EKMS trust graph attestation export enhancement, and finalize training outcomes metrics (see Section 14).
- Quarterly Governance Board (CISO-led): The Policy Steering Committee (PSC) reviews aggregate performance, risk posture, and roadmap investments. The Q2 2026 packet (PSC-PKT-2026-Q2) included a year-to-date trend analysis indicating sustained compliance within SLOs and a projection of telemetry pipeline capacity for the planned expansion of signed internal data artifacts in Q4. The PSC accepted the packet and requested an update on cross-business attestation normalization (Action PSC-ACT-2026-06-27-01), due by 2026-08-15.

All governance artifacts are classified Internal -- Confidential and stored in the enterprise collaboration repository with retention aligned to Section 12. Deviations, material or anticipated, must be recorded as observations with owners, due dates, and measurable outcomes. As of 2026-06-30, no material deviations to this policy were open.

14. Training and Awareness

Competency in artifact signing and attestation is a prerequisite for all roles that design, operate, or consume the release processes. Meridian Capital's Learning & Development (L&D), in collaboration with DSE and RCC, maintains a

structured curriculum delivered through the corporate Learning Management System (LMS). The curriculum includes (a) Foundational training for engineering and release management roles (course ID: LMS-SC-101), (b) Advanced topics for build pipeline maintainers (course ID: LMS-SC-201), and (c) Governance and audit awareness for control owners and approvers (course ID: LMS-SC-301). Annual refresher requirements apply to all courses.

Completion of LMS-SC-101 is mandated within 30 days of role assignment and annually thereafter; LMS-SC-201 and LMS-SC-301 require completion within 60 days of assignment. L&D publishes completion metrics monthly to RCC and the PSC. For the period ending 2026-06-30T23:59:59Z, completion rates were: LMS-SC-101 at 98.8% (target >= 98%), LMS-SC-201 at 96.4% (target >= 95%), and LMS-SC-301 at 99.1% (target >= 98%). Two business units reported onboarding spikes during Q2; temporary variances were tracked under LRN-TRK-2026-06-1120 and LRN-TRK-2026-06-1429 and closed with completions by 2026-07-08.

Awareness campaigns accompany material changes to the policy or supporting platforms. Communications are issued via the enterprise bulletin (EBN) with references to approved change tickets. The EKMS trust graph enhancement (CHG-2026-06-1205) and SCTS evidence bundling update (RFC-2026-06-1217) were each accompanied by EBN notices (EBN-2026-06-13 and EBN-2026-06-18), reinforced with office hours hosted by DSE. Attendance and Q&A outcomes are recorded and linked to the relevant change records for auditability.

Page 12 -- Artifact Signing and Attestation Policy (Meridian Capital)

15. Continuous Improvement and Corrective Actions

Meridian Capital adopts a continuous improvement approach centered on data-driven adjustments and structured corrective and preventive actions (CAPA). Non-conformities, near-misses, and enhancement opportunities are logged in the enterprise quality system with unique references and linked evidence. CAPA records must specify the observation, root cause, corrective action, preventive measures, and validation criteria, along with named accountable owners and due dates. CAPA-2026-003 (opened 2026-05-21T10:18:44Z) addressed minor inconsistencies in attestation bundle metadata emitted by one CI instance. Root cause analysis identified configuration drift following a planned platform upgrade; corrective actions standardized the emitter configuration and introduced an integrity cross-check in SCTS's ingestion pipeline. Validation was completed on 2026-06-05T12:03:11Z with RCC sign-off; no recurrence has been observed.

The continuous improvement roadmap is refreshed quarterly and aligned to PSC priorities. Current areas of focus include (a) enhanced lineage visualization in the Release Governance Ledger to reduce investigator mean time to materiality determination (MTMD), (b) normalization of attestation schemas across heterogeneous build systems to streamline enterprise-level analytics, and (c) expanded telemetry resiliency testing under Business Continuity Test scenario BCT-2A. Progress against the roadmap is tracked via Epics in the Portfolio Management System (e.g., PMO-EPIC-SC-2026-07) with measurable outcomes documented in the PSC packet. As of 2026-06-30, the lineage visualization enhancement achieved 70% feature completeness, and schema normalization reached 60% adoption across active pipelines.

16. Policy Maintenance and Change Control

This policy is maintained by the Head of DevSecOps Engineering as Policy Owner, with RCC as Control Owner and the CISO serving as Executive Sponsor. Proposed changes follow the formal change control process with dual-track evaluation: (a) policy language review (clarity, scope, control mapping) and (b) operational impact assessment (training, telemetry, and audit readiness). All changes require a Change Advisory Board (CAB) decision and PSC notification when material. The policy version is updated only upon CAB approval and completion of downstream readiness activities.

Each proposed revision is raised as a Request for Change (RFC) that includes rationale, redlined text, and evidence of stakeholder consultation. The latest update, RFC-2026-07-0912, consolidated KPI definitions and clarified evidence retention alignment with enterprise records policy. CAB approved the change on 2026-07-12T15:30:00Z under CHG-2026-07-0912; the effective date was set to 2026-07-19T00:00:00Z to allow for awareness communications (EBN-2026-07-13) and LMS microlearning publication (LMS-SC-101A). Non-material corrections (typos, formatting, broken references) may be processed as Editorial Amendments with documentation in the policy repository, but the version number remains unchanged. All materials associated with policy maintenance are classified Internal -- Confidential.

17. Document Control, Distribution, and Contacts

Document Classification: Internal -- Confidential. Document ID: POL-SC-ARTSIGN-001. Current Version: 1.2. Effective Date: 2026-07-19. System of Record: Policy Repository (POL-REP), with signed PDFs and hash manifests stored in Records & Archives WORM storage per Section 12. Distribution is restricted to Meridian Capital employees and approved contractors with a legitimate business need. Managed copies exist only within the Policy Repository; locally stored or printed versions are considered uncontrolled. The authoritative version is the digitally signed copy in POL-REP, verified by the enterprise document signing service. Any discrepancies between local copies and the authoritative version must be resolved in favor of the authoritative version.

For questions on interpretation or implementation, the following contacts apply:

- Policy Owner: Head of DevSecOps Engineering (DSE), mailbox: dse-policy@meridiancapital.example.
- Control Owner: Risk, Controls & Compliance (RCC), mailbox: rcc-controls@meridiancapital.example.
- Evidence and Audit Requests: Records & Archives (R&A), mailbox: records@meridiancapital.example.
- Telemetry and Dashboards: Supply Chain Telemetry Service (SCTS), mailbox: scts@meridiancapital.example.

Inquiries received are tracked via Service Desk tickets with time-to-first-response target of 1 business day and time-to-resolution target of 5 business days. Metrics for June 2026 (SRV-MON-2026-06) indicate 100% compliance with response targets across 42 tickets.

18. Glossary and Acronyms

- Artifact: A discrete, versioned output of a build process (e.g., package, container image) that is promoted through release stages and subject to signing and attestation.
- Attestation: A cryptographically verifiable statement asserting properties of an artifact (e.g., provenance, build environment, SBOM) linked to the artifact's immutable identifier.
- Attestation Freshness: The temporal delta between the creation of an attestation and the promotion of the associated artifact.
- EKMS: Enterprise Key Management Service responsible for the lifecycle of cryptographic keys and trust policy enforcement.
- Provenance: Evidence describing how an artifact was produced, including source references and build parameters, captured in a standardized format.
- Release Governance Ledger (RGL): The authoritative record of approvals, signatures, attestations, and promotion decisions for releasable artifacts.
- Root of Trust (Trust Root): A cryptographic anchor approved by Meridian Capital and governed by EKMS Trust Policy.
- SCTS: Supply Chain Telemetry Service that aggregates, normalizes, and signs control telemetry for dashboards and audits.
- SLO: Service Level Objective indicating the target performance threshold for a metric.
- WORM: Write Once Read Many storage capability used for records immutability.

19. Approval and Revision History

Policy POL-SC-ARTSIGN-001 was initially approved by the CISO on 2025-03-15T10:00:00Z (Version 1.0; CHG-2025-03-0411). Version 1.1 (effective 2026-02-10; CHG-2026-02-0307) introduced KPI formalization, expanded attestation coverage requirements, and aligned evidence retention with updated records schedules. Version 1.2 (effective 2026-07-19; CHG-2026-07-0912) refined KPI definitions, clarified governance cadence responsibilities, and updated references to EKMS trust graph attestations. Each version has been accompanied by an awareness bulletin and LMS updates, with completion tracking reported to RCC and the PSC.

The CISO retains final approval authority. Approvals are captured as digitally signed endorsements in the Policy Repository; the Version 1.2 approval record is PR-APP-2026-07-12-001, signed 2026-07-12T15:34:22Z. Control Owner concurrence is recorded as RCC-CON-2026-07-12-019. No open actions remain associated with Version 1.2 at the time of publication.

This policy concludes on Page 12. For related standards and implementation guidelines, refer to the following controlled documents: STD-SC-SIGN-002 (Signing Implementation Standard), STD-SC-ATTEST-003 (Attestation Content Standard), and PRO-SC-EVID-004 (Evidence Packaging Procedure). All references are available in the Policy

Repository and are subject to the same document control provisions described above.